

Vejledning til tilbudsgiver

Denne vejledningstekst og øvrige vejledningstekster i bilaget slettes forud for kontraktindgåelse.

Bilaget skal ikke udfyldes af Tilbudsgiver.

- Bilaget er i det hele et mindstekrav .

Bilag 8-1 og 8-2 udfyldes i forbindelse med kontraktindgåelsen.

Kirkenettet

Databehandleraftale & databehandlerinstruks

i henhold til kontrakt om
levering og vedligeholdelse af et ESDH-system

mellem
Folkekirkens It
CVR nr. 2720 6808

og

[Leverandør]
CVR nr. [xxxx xxxx]

(benævnt Parterne)

Folkekirkens It, CVR nr. 2720 6808

Dato:

Dokument nr. *





1. Denne Databehandleraftale og databehandlerinstruks (herefter "Databehandleraftale") knytter sig til kontrakt mellem Folkekirken's It og Leverandøren indgået den **[dd.mm.åååå]** (herefter "Kontrakten") vedrørende levering og vedligeholdelse af et ESDH-system (herefter "Leverancen"), hvor data opbevares på de fysiske lokaliteter, der er anført i bilag 8-1. Lokaliteterne skal befinde sig indenfor EU, medmindre andet skriftligt aftales.

Databehandleraftalen er en databehandlingsaftale, jf. Persondatalovens § 42, stk. 2, og vedrører behandling af personhenførbare oplysninger (herefter "personoplysninger"). I det omfang oplysninger, der ved lov eller aftale er gjort fortrolige, behandles i medfør af Databehandleraftalen, omfatter enhver henvisning til "personoplysninger" under Databehandleraftalen også de fortrolige oplysninger.

Typen af personoplysninger, der behandles under denne Databehandleraftale, kategorier af registrerede og formålet med databehandlingen skal inden den 25. maj 2018 nærmere beskrives i bilag 8-2 til Databehandleraftalen. Databehandler forpligter sig til – uden beregning – at levere de oplysninger til Dataansvarlig, som er nødvendige for, at bilag 8-2 kan færdiggøres, senest 1 måned efter forudgående skriftlig meddelelse fra Dataansvarlig med angivelse af, hvilke oplysninger, Dataansvarlig har brug for fra Databehandler for at bilag 8-2 kan færdiggøres.

Bestemmelser i Databehandleraftalen, Kontraktens punkt 24 og de i øvrigt relevante bestemmelser i Kontrakten gælder for behandling af personoplysninger i forbindelse med Leverancen. I tilfælde af uoverensstemmelse mellem aftalerne har Databehandleraftalen forrang, for så vidt angår behandlingen af personoplysninger.

2. Leverandøren handler som databehandler og Folkekirken's It som dataansvarlig i henhold til lov om behandling af personoplysninger § 42 (Persondataloven), når Leverandøren foretager behandling af personoplysninger i medfør af Kontrakten. Følgelig benævnes Folkekirken's It i denne Databehandleraftale også som "Dataansvarlig" og Leverandøren også som "Databehandler".

3. Databehandleren forpligter sig til at overholde de til enhver tid gældende lovgivningsmæssige krav i forbindelse med den databehandling, som udføres for den Dataansvarlige. Ingen af Parterne kan påberåbe sig Databehandleraftalens





indhold i et tilfælde, hvor dette ville indebære en overtrædelse af sådanne lovgivningsmæssige krav. Hvis Databehandler er etableret i en anden EU-medlemsstat, skal de bestemmelser om sikkerhedsforanstaltninger, som er fastsat i lovgivningen i den EU-medlemsstat, hvor Databehandler er etableret, derudover gælde for Databehandler. Hvis Databehandler er etableret i en anden EU-medlemsstat, skal Databehandler således overholde både de danske sikkerhedskrav i Persondataloven og sikkerhedskravene i leverandørens hjemland. Når reguleringen i henhold til den kommende EU persondataforordning træder i kraft, jf. nedenfor, skal denne på tilsvarende vis gælde med tillæg af de specifikke krav, der måtte blive fastlagt i hvert enkelt medlemsland.

Leverandøren skal i henhold til denne Databehandleraftale overholde de til enhver tid gældende regler og forskrifter for behandling af personoplysninger, herunder:

- lov nr. 429 af 31/05/2000 med senere ændringer om behandling af personoplysninger (Persondataloven).
- bekendtgørelse nr. 528 af 15/06/2000 med senere ændringer (Sikkerhedsbekendtgørelsen)
- vejledning nr. 37 af 02/04/2001 til bekendtgørelse nr. 528 af 15/06 2000 (Sikkerhedsvejledningen)
- cirkulære om informationssikkerhed, herunder sikkerhedsforanstaltninger i Kirkenettet af 06/06/2016 (sikkerhedscirkulæret).

samt, ved persondatalovens samtidige ophør, EU forordning 2016/679 af 27. april 2016 om persondatabeskyttelse, som får virkning den 25. maj 2018.

4. Personoplysninger må alene behandles til formål, som er nødvendige for Databehandlers levering af Leverancen. Databehandler handler alene efter instruks fra den dataansvarlige. Dataansvarlig afgør, til hvilke formål og hvordan, herunder med hvilke hjælpemidler, der må foretages behandling af personoplysninger, hvilket fremgår af Kontrakten.

Databehandler er underlagt forvaltningslovens regler om tavshedspligt. Alle person- og virksomhedsoplysninger, som Databehandler får adgang til, er fortrolige.





Databehandleren indestår for, at denne Databehandlersaftale efterleves af Databehandlerens ansatte, og ansatte hos en eventuel underleverandør, der varetager behandling af personoplysninger under denne Databehandlersaftale, jf. punkt 5. I den forbindelse er Databehandler forpligtet til at begrænse adgangen til personoplysninger til de medarbejdere, som har et arbejdsbetinget behov for at kunne behandle personoplysninger for at kunne opfylde Databehandlers forpligtelser over for Dataansvarlige. Kun de personer, som autoriseres hertil, må have adgang til de personoplysninger, der behandles.

5. Databehandler må ikke indgå aftaler med underleverandører om behandling af personoplysninger omfattet af Databehandlersaftalen, medmindre Dataansvarlig forinden skriftligt har samtykket til aftaleindgåelsen, jf. også Kontraktens punkt 5.9 og 17.6. Databehandler skal i sin aftale med underleverandøren sikre sig, at underleverandøren som minimum accepterer de samme forpligtelser som Databehandler har påtaget sig ved Databehandlersaftalen, for så vidt angår den behandling af Dataansvarliges personoplysninger, der varetages af underleverandøren. Det er Databehandlers ansvar at sikre sig, at underleverandøren lever op til kravene i henhold til denne Databehandlersaftale, herunder indgåelse af Databehandlersaftale med underleverandøren.

Databehandler må ikke overføre eller tillade overførsel af personoplysninger til lande uden for det Europæiske Økonomiske Samarbejdsområde uden Dataansvarliges forudgående skriftlige samtykke. Såfremt Dataansvarlig har givet tilladelse til en overførsel, påhviler det Databehandleren at sikre, at der foreligger et lovligt overførselsgrundlag, f.eks. EU Kommissionens standardkontrakter til overførsel af personoplysninger til tredjelande, forud for påbegyndelsen af behandlingen af personoplysninger i henhold hertil.

6. Reglerne i Persondatalovens § 41, stk. 3-5, gælder ligeledes for Databehandlerens behandling af personoplysninger under denne Databehandlersaftale.

Databehandler træffer de fornødne tekniske og organisatoriske sikkerhedsforanstaltninger mod, at oplysninger hændeligt eller ulovligt tilintetgøres, fortabes eller forringes samt mod, at data eller informationer kommer til uvedkommendes kendskab, misbrug eller i øvrigt behandles i strid med de til enhver tid gældende regler og forskrifter for behandling af personoplysninger.





Databehandlers fastlæggelse og overholdelse af de fornødne tekniske og organisatoriske sikkerhedsforanstaltninger skal ske under iagttagelse af den til enhver tid værende relevante branchestandard for informationssikkerhed, som på tidspunktet for Kontraktens indgåelse udgøres af ISO 27001, jf. også Kontraktens punkt 5.8 om sikkerhed med tilhørende bilag.

Sikkerhedsforanstaltningerne skal omfatte alle de foranstaltninger, som er nødvendige i relation til sikker behandling af persondata efter den Dataansvarliges årlige risikovurdering af behandlingen samt karakteren af de personoplysninger, der skal beskyttes. Som en del heraf skal Databehandler sikre overholdelse af sikkerhedsvejledningens krav til styring af autorisationer og adgangskontrol, logning m.v. jf. også Databehandlertaftalens punkt 6.1-6.3.

6.1 Særlige sikkerhedsforanstaltninger

Leverandøren har pligt til at efterleve og opfylde betingelserne i Governance¹ for Kirkenettet samt at fastsætte og gennemføre de i sikkerhedsbekendtgørelsen krævede interne bestemmelser om sikkerhedsforanstaltninger.

Leverandøren skal i sine retningslinjer fastsætte regler, der sikrer, at dennes ansatte kun har adgang til personoplysninger, som er nødvendige for den ansattes udførelse af sine arbejdsopgaver.

Det indskræpes særligt, at medarbejdere der tildeles administratorrettigheder

- skal anvende et administratorpassword der lever op til anbefalingerne i Center for Cybersikkerheds passwordvejledning
- som hovedregel skal anvende en brugerkonto, som ikke har administratorrettigheder og kun ved en systemunderstøttet procedure får tildelt en administratoradgang i et nærmere angivet tidsrum.

De interne retningslinjer skal gennemgås mindst én gang om året med henblik på at sikre, at de er fyldestgørende og afspejler de faktiske forhold, og Leverandøren er pligtig at uddanne alle sine ansatte, der beskæftiger sig med ESDH-systemet i overholdelsen af retningslinjerne.

Retningslinjerne skal være udformet efter Datatilsynets vejledning til sikkerhedsbekendtgørelsen (se www.datatilsynet.dk). Opmærksomheden

¹ Dnr 134951-14 Governance i Kirkenettet af 03/12/2014





henledes på, at der i henhold hertil gælder særligt skærpede krav for behandling af følsomme oplysninger.

Folkekirken's It kan til enhver tid kræve at få udleveret kopi af de interne sikkerhedsforskrifter.

6.2 Beskyttelse af personoplysninger i åbne net.

Ved tilslutning til internet eller andre åbne net træffes foranstaltninger, som sikrer mod uvedkommende trafik og forhindrer adgang fra det åbne net til den Dataansvarliges interne net. Leverandøren skal i denne forbindelse overholde de retningslinjer, som til enhver tid er fastsat af Datatilsynet.

Ved indgåelse af denne aftale skal Leverandøren som minimum træffe følgende foranstaltninger:

- Etablering og vedligeholdelse af en firewall, som sikrer gennemførelse af it-sikkerhedspolitik for Kirkenettet, herunder f.eks. spærring for adgang til visse hjemmesider.
- Ajourføring af servere og pc-arbejdspladser med sikkerhedsopdateringer, som sikrer mod ondsindet udnyttelse af sårbarheder i de anvendte programmer.
- Etablering af virusværn, som løbende ajourføres. Et virusværn vil bl.a. sikre mod en del af den ondsindede spyware.
- Opsætning af sikkerhedsindstillingerne i browseren og e-mail klienten på de enkelte pc-arbejdspladser, således at der opnås den ønskede sikkerhedspolitik omkring websteder, cookies og modtagelse af eksekverbar kode (plug-ins m.v.)

Efter en vurdering af den konkrete sikkerhedsrisiko og under hensyntagen til øvrige sikkerhedsforanstaltninger kan yderligere sikkerhedsforanstaltninger være hensigtsmæssige og/- eller nødvendige.

6.3 Krav til lagring og udskrivning af oplysninger uden for Leverandørens lokaliteter.

Det er kun tilladt for Leverandørens ansatte at beskæftige sig med ESDH-systemet fra hjemmearbejdspladser eller mobile arbejdsstationer, såfremt disse er forsynet med samme sikkerhedsanordninger som i øvrigt er gældende for arbejdspladsen som sådan, herunder stærk kryptering mv. ligesom





dataforbindelse fra hjemmearbejdspladsen til det centrale system skal have et tilstrækkeligt sikkerhedsniveau til behandlingen af data.

Anvendelse af hjemmearbejdspladser eller mobile arbejdsstationer forudsætter, at personoplysninger udelukkende behandles og bearbejdes fra en lokalitet i EU, medmindre dataansvarliges forudgående skriftlige samtykke indhentes.

Derudover, skal Leverandøren særligt sikre følgende:

Hvis det er nødvendigt, at hjemme-pc'en ikke bare anvendes som terminal mod det centrale system, men også til lagring af oplysninger fra det centrale system, skal oplysningerne krypteres.

Hvis det er nødvendigt, at der skal udskrives oplysninger fra hjemme-pc'en, skal der fastsættes regler og gives instruktion vedrørende opbevaring og tilintetgørelse af udskrifter, så oplysningerne ikke kommer uvedkommende til kendskab.

Hvis Leverandøren tillader anden anvendelse af hjemme-pc'en, f.eks. til privat brug og/eller af andre end den ansatte, skal der fastsættes retningslinjer for denne anvendelse og etableres de nødvendige sikkerhedsforanstaltninger i forbindelse dermed, herunder passwordbeskyttelse.

Leverandøren skal endvidere være opmærksom på den fysiske sikring i hjemmemiljøet, herunder mod tyveri, hærværk og uvedkommendes adgang.

Der skal løbende ske ajourføring af de særlige retningslinjer vedrørende hjemmearbejdspladser for at sikre, at bestemmelserne om sikkerhedsforanstaltninger iagttages.

7. Databehandler skal på Dataansvarliges anmodning assistere Dataansvarlig med at overholde de forpligtelser, Dataansvarlig er underlagt i henhold til gældende regulering, på alle de områder hvor Dataansvarliges opfyldelse af sådanne forpligtelser afhænger af Databehandlerens assistance, herunder overholdelse af indsichtsretten overfor de registrerede og gennemførelse af nødvendige risiko- og konsekvensanalyser og eventuelle høringer i den forbindelse.

Databehandler skal på Dataansvarliges anmodning give Dataansvarlig tilstrækkelige oplysninger til at Dataansvarlig kan påse, at de nævnte tekniske og organisatoriske sikkerhedsforanstaltninger er truffet. Endvidere skal





Databehandler til enhver tid kunne dokumentere, at identificerede sårbarheder bliver imødegået ud fra en risikobaseret vurdering.

Dataansvarlig kan til enhver tid med et passende skriftligt varsel anmode om tilvejebringelse af dokumentation for, at tilstrækkelige sikkerhedsmæssige foranstaltninger er gennemført hos Databehandleren.

Databehandler skal afgive en erklæring fra en statsautoriseret revisor til den Dataansvarlig, der dokumenterer, om kravene til de persondataretlige sikkerhedsmæssige forhold hos Databehandler i henhold til persondatareguleringen med tillæg af gældende relevante it-sikkerheds forskrifter og standarder er overholdt. Erklæringen afgives som en del af eller samtidig med den i Kontraktens punkt 5.8 anførte erklæring i henhold til den til enhver tid gældende revisionsstandard om Leverandørens generelle system-, drifts- og datasikkerhed fra Leverandørens eksterne statsautoriserede revisor.

Erklæringen afgives første gang senest 1 måned efter Ibrugtagningdagen for hele eller dele af Systemet og herefter én gang årligt, jf. Kontraktens punkt 5.8.

I det omfang, revisionserklæringen giver anledning til anmærkninger, som er relevante for databehandling i henhold til denne Databehandleraftale, er Databehandler forpligtet til uden ugrundet ophold at efterkomme de anvisninger, der måtte følge af revisionserklæringen, jf. Kontraktens punkt 5.8.

Databehandler er forpligtet til at acceptere audit og inspektionsbesøg i henhold til bestemmelserne i Kontraktens punkt 5.7 (Audit).

Databehandler har pligt til at deltage i eventuelle drøftelser med Datatilsynet og indarbejde eventuelle anbefalinger og/eller påbud mv. fra tilsynet vedrørende behandling af personoplysninger som led i udførelsen af databehandlingen.

8. Denne Databehandleraftale og databehandlerinstruks kan til enhver tid ændres umiddelbart med skriftligt varsel, såfremt ændringen er nødvendig for at overholde de til enhver tid gældende regler og forskrifter for behandling af personoplysninger, herunder overholde ændringer i Persondataloven², sikkerhedsbekendtgørelsen³, sikkerhedsvejledningen⁴ samt cirkulære om informationssikkerhed, herunder sikkerhedsforanstaltninger i Kirkenettet⁵ jf.

² LOV nr 429 af 31/05/2000 med evt. senere ændringer

³ BEK nr 528 af 15/06/2000 med evt. senere ændringer

⁴ VEJ nr 37 af 02/04/2001

⁵ CIR af 06/06/2016





også punkt 3.

9. Oplysninger må ikke opbevares længere end nødvendigt af hensyn til de formål, hvortil de er indsamlet. Dataansvarlig konsulteres ved tvivlsspørgsmål herom.

Oplysninger må ikke videregives til tredjemand, medmindre dette er påkrævet ifølge gældende lovgivning eller aftale med Dataansvarlig.

I det omfang, der lovligt kan eller skal ske elektronisk udveksling af personoplysninger med tredjemand, skal dette ske under anvendelse af stærk kryptering.

10. Databehandler er forpligtet til at underrette Dataansvarlig skriftligt ved kendskab til enhver afvigelse, der potentielt kan forøge risikoen for brud på datasikkerheden, f.eks. ved:

- fravigelse fra de aftalte sikkerhedsforanstaltninger
- mistanke om brud på fortroligheden
- enhver mistanke om misbrug, fortabelse og forringelse af data

Ved enhver mistanke om alvorlig misligholdelse af Databehandleraftalen og/eller Kontrakten, der kan medføre brud på datasikkerheden, skal Dataansvarlig endvidere straks underrettes.

I tilfælde af brud på datasikkerheden skal Databehandler give Dataansvarlig underretning, jf. Kontraktens punkt 24.

Derudover skal Dataansvarlig underrettes ved:

- (i) enhver anmodning om videregivelse af personoplysninger omfattet af Databehandleraftalen fra en myndighed, medmindre orientering af Dataansvarlig er forbudt ved lov eller bestemmelser fastsat i henhold til lov
- (ii) enhver hændelig eller uautoriseret videregivelse af eller adgang til personoplysninger behandlet efter Databehandleraftalen,
- (iii) enhver anmodning om indsigt modtaget direkte fra den registrerede eller fra tredjemand, medmindre orientering af Dataansvarlig er forbudt ved lov eller bestemmelser fastsat i henhold til lov





11. Databehandleraftalen træder i kraft ved begge Parter underskrift og er gældende indtil den opsiges eller ophæves af en af Parterne. Den ophører senest ved ophør af Kontrakten, medmindre der træffes anden særskilt skriftlig aftale mellem Parterne.

Ved ophør gælder vilkårene i Kontraktens punkt 28.4 (Forpligtelser ved ophør).

Databehandleraftalen kan ophæves af begge Parter ved væsentlig misligholdelse i overensstemmelse med de almindelige regler i den gældende lovgivning.

Dataansvarlig kan også ophæve Databehandleraftalen med øjeblikkelig virkning, såfremt en myndighed, der efter lovgivningen er kompetent hertil, kræver dette.

Uanset Databehandleraftalens formelle aftaleperiode, skal Databehandleraftalen gælde, så længe Databehandler fortsat behandler Dataansvarliges personoplysninger.

12. Underskrifter

Aftalen underskrives i 2 eksemplarer, hvoraf et opbevares af Folkekirkens It og et opbevares af Leverandøren.

Begge Parter skal opbevare Databehandleraftalen i 5 år efter Databehandleraftalens ophør

for Leverandøren den / -

For Folkekirkens It den / -

.....

underskrift

Navn: *
Stilling: *

.....

underskrift

Navn: *
Stilling: *





Bilag 8-1 Lokalteter hvor data i henhold til kontrakt om levering og vedligeholdelse af et ESDH-system opbevares.

[For hver lokalitet angives i forbindelse med kontraktindgåelse en fuldstændig postadresse samt oplysninger (navn, telefonnr. og email) om den kontaktperson den Dataansvarlige kan henvende sig til.]





Bilag 8-2 Typen af personoplysninger, der behandles under denne Databehandlersaftale, kategorier af registrerede og formålet med databehandlingen

[Bilaget udfyldes inden den 25. maj 2018.]





Kirkeministeriet

**Bilag 8-3 Cirkulære om informationssikkerhed, herunder
sikkerhedsforanstaltninger i Kirkenettet af 6. januar 2017**

[Særskilt bilag vedlagt]





**Bilag 8-4 Bilag til Cirkulære om informationssikkerhed, herunder
sikkerhedsforanstaltninger i Kirkenettet af 6. januar 2017**

[Særskilt bilag vedlagt]





Bilag 8- 5 Governance i Kirkenettet

[Særskilt bilag vedlagt]

